

가상기관 정보보안 운영지침

가상기관 규정 제2027-2호 · 2027. 1. 1. 시행

제1조(목적)

- ① 이 지침은 가상기관(이하 "기관"이라 한다)의 정보자산을 내부·외부의 각종 위협으로부터 보호하기 위한 정보보안 업무의 기준과 절차를 정함을 목적으로 한다.
- ② 정보보안에 관하여 다른 규정에 특별한 정함이 없으면 이 지침에서 정하는 바에 따른다.

제2조(정의)

- ① "정보자산"이란 기관이 보유한 정보와 이를 처리하는 서버, 네트워크 장비, 소프트웨어, 문서 등 일체의 자산을 말한다.
- ② "침해사고"란 해킹, 악성코드 감염, 서비스 거부 공격 등으로 정보자산에 피해가 발생하였거나 발생할 우려가 있는 사고를 말한다.
- ③ "정보보안 담당자"란 부서별로 정보보안 업무를 담당하도록 지정된 자를 말한다.

제3조(적용 범위)

- ① 이 지침은 기관의 모든 임직원과 기관의 정보자산에 접근하는 외부 인력에게 적용한다.
- ② 이 지침은 기관이 구축·운영하는 모든 정보시스템과 네트워크에 적용한다.
- ③ 외부에 위탁하여 운영하는 정보시스템에 대하여도 계약이 정하는 범위에서 이 지침을 적용한다.

제4조(정보보안 조직)

- ① 기관장은 정보보안 업무를 총괄하는 정보보안책임자를 지정한다.

- ② 정보보안책임자는 보안정책의 수립, 위험관리, 침해사고 대응 등 정보보안 업무 전반을 관장한다.
- ③ 각 부서의 장은 소속 부서의 정보보안 담당자를 지정하고, 그 역할과 책임을 문서로 정한다.

제5조(정보자산의 식별 및 분류)

- ① 각 부서는 보유한 정보자산을 식별하여 정보자산 목록에 등록한다.
- ② 정보자산에는 기밀성, 무결성, 가용성을 고려한 중요도 등급을 부여한다.
- ③ 정보자산 목록은 연 1회 이상 현행화하고 변경 사항을 반영한다.

제6조(위험평가)

- ① 정보보안책임자는 연 1회 이상 정보자산에 대한 위험평가를 실시한다.
- ② 위험평가 결과 수용할 수 없는 위험에 대하여는 보호대책과 이행 일정을 포함한 위험 처리 계획을 수립한다.
- ③ 위험 처리 계획의 이행 현황은 반기별로 점검한다.

제7조(계정 및 비밀번호 관리)

- ① 정보시스템의 계정은 사용자별로 발급하고 여러 사람이 함께 사용하는 공용 계정의 사용을 금지한다.
- ② 계정의 발급과 회수는 승인 절차를 거쳐 처리하고 그 내역을 기록한다.
- ③ 비밀번호는 문자, 숫자, 특수문자를 조합하여 일정 길이 이상으로 작성하도록 규칙을 정하여 적용한다.
- ④ 퇴직, 전보 등의 사유가 발생한 경우에는 해당 계정을 지체 없이 회수하거나 말소한다.

제8조(접근권한 관리)

- ① 정보시스템에 대한 접근권한은 업무상 필요한 최소한의 범위로 부여한다.

- ② 접근권한의 적정성을 분기별 1회 이상 검토하고 불필요한 권한은 회수한다.
- ③ 권한 검토 결과와 조치 내역은 기록으로 남긴다.

제9조(네트워크 보안)

- ① 업무망과 외부 인터넷 구간은 침입차단시스템 등 보안장비로 접근을 통제한다.
- ② 네트워크는 업무 특성과 중요도에 따라 영역을 분리하여 운영한다.
- ③ 방화벽 등 보안장비의 정책은 반기별로 검토하여 불필요하거나 중복된 정책을 정비한다.

제10조(서버 보안)

- ① 서버는 보안 설정 기준에 따라 설치·운영하고 불필요한 서비스와 계정은 제거한다.
- ② 운영체제와 소프트웨어의 보안 업데이트는 업무 영향도를 검토한 후 지체 없이 적용한다.
- ③ 보안 업데이트의 적용 내역은 기록하여 관리한다.

제11조(악성코드 대응)

- ① 모든 업무용 단말과 서버에는 백신 소프트웨어를 설치하고 최신 상태로 유지한다.
- ② 악성코드 감염이 의심되는 경우 즉시 해당 장비를 네트워크에서 분리하고 정보보안 담당자에게 신고한다.
- ③ 백신 소프트웨어에 의한 정기 검사를 주 1회 이상 수행한다.

제12조(로그 관리)

- ① 주요 정보시스템의 접속 및 작업 로그를 수집하여 6개월 이상 보관한다.
- ② 로그는 위·변조를 방지할 수 있는 방법으로 별도 보관한다.
- ③ 정보보안 담당자는 주요 시스템의 로그를 월 1회 이상 점검하고 이상 징후를 분석한다.

제13조(백업 및 복구)

- ① 주요 정보시스템의 데이터는 백업 정책에 따라 주기적으로 백업한다.
- ② 백업 매체는 원본과 물리적으로 분리된 안전한 장소에 보관한다.
- ③ 백업 데이터의 복구 가능 여부를 반기별 1회 이상 시험하고 그 결과를 기록한다.

제14조(암호 통제)

- ① 중요 정보는 안전성이 검증된 암호 알고리즘으로 암호화하여 저장·전송한다.
- ② 암호화 대상, 사용 알고리즘, 암호키 관리 절차를 정한 암호 통제 기준을 수립·운영한다.
- ③ 암호키는 접근 권한을 가진 자만 취급할 수 있도록 안전하게 생성·보관·폐기한다.

제15조(침해사고 대응)

- ① 기관은 침해사고 대응 절차를 수립하고 사고 유형별 보고 체계를 정한다.
- ② 침해사고를 인지한 임직원은 즉시 정보보안 담당자와 정보보안책임자에게 보고한다.
- ③ 침해사고 처리 후에는 원인을 분석하고 재발 방지 대책을 수립한다.
- ④ 기관은 연 1회 이상 침해사고 대응 모의훈련을 실시한다.

제16조(업무연속성 및 재해복구)

- ① 기관은 재해·재난에 대비하여 주요 정보시스템의 복구 목표와 절차를 정한 재해복구 계획을 수립한다.
- ② 재해복구 계획에는 시스템별 복구 우선순위와 비상연락체계를 포함한다.
- ③ 재해복구 계획에 따른 훈련을 연 1회 이상 실시하고 그 결과를 반영하여 계획을 보완한다.

제17조(외부자 보안)

- ① 외부 용역, 유지보수 등으로 정보자산에 접근하는 외부자와는 보안 준수 사항이 포함된 계약을 체결한다.
- ② 외부자의 정보시스템 접근은 필요한 기간과 범위로 한정하고 작업 내역을 기록한다.
- ③ 계약이 종료된 때에는 외부자에게 부여한 계정과 접근권한을 즉시 회수한다.

제18조(정보보안 교육)

- ① 기관은 전 임직원을 대상으로 연 1회 이상 정보보안 교육을 실시한다.
- ② 정보보안 업무 담당자에게는 연 1회 이상 별도의 전문 교육을 제공한다.
- ③ 교육 실시 결과는 문서로 기록하여 보관한다.

제19조(정보보안 점검)

- ① 정보보안책임자는 이 지침의 이행 실태를 연 1회 이상 점검한다.
- ② 점검 결과와 개선 조치 계획을 기관장에게 보고한다.
- ③ 발견된 취약점은 조치 기한을 정하여 개선하고 그 이행 여부를 확인한다.

제20조(지침의 개정)

- ① 이 지침은 관련 법령의 개정 또는 보안 환경의 변화에 따라 개정할 수 있다.
- ② 이 지침에서 정하지 아니한 세부 사항은 정보보안책임자가 따로 정할 수 있다.
- ③ 지침의 개정 이력은 부록의 개정 이력표에 기록한다.

부칙

- ① 이 지침은 2027년 1월 1일부터 시행한다.

② 이 지침 시행 전에 처리된 사항은 이 지침에 따라 처리된 것으로 본다.